

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	• <i>The app will process transactions</i> • <i>The app does involve significant back-end processing to handle user accounts, private messages, payment transactions, and seller ratings securely.</i> • <i>The app must support secure and reliable payment processing with multiple payment options to ensure smooth transactions and compliance with regulations.</i>
II. Define the technical scope	List of technologies used by the application: • <i>Application programming interface (API)</i> • <i>Public key infrastructure (PKI)</i> • <i>SHA-256</i> • <i>SQL</i> I would prioritize evaluating the API first because it acts as the main communication channel between users, the app, and third-party services. APIs often expose sensitive data and endpoints that attackers can exploit if not properly secured. A vulnerable API could compromise authentication, payment processing, and overall data integrity across the entire system.
III. Decompose application	Sample data flow diagram
IV. Threat analysis	Internal Threats: • Insider misuse or privilege abuse: An employee with access to private information could intentionally or accidentally expose or modify sensitive user or payment data. External Threats: • Phishing or credential theft: Attackers could trick users or employees into revealing login credentials, giving them unauthorized access to the system.
V. Vulnerability analysis	Vulnerability 1 – API and Codebase Weaknesses: • The API could be vulnerable to improper input validation or insecure authentication logic, which might allow attackers

	to perform SQL injection or unauthorized access. This can expose sensitive customer data and disrupt communication between the app and server. Vulnerability 2 – Database and Network Weaknesses: • The SQL database may lack proper encryption at rest or access control, making it easy for privilege escalation attacks. Additionally, weak network configurations or outdated patches could allow attackers to alter data in transit.
VI. Attack modeling	Sample attack tree diagram
VII. Risk analysis and impact	• Multi-Factor Authentication (MFA): Adds an extra layer of protection by requiring more than just a password to access user accounts or administrative tools. • Encryption (AES/RSA): Protects sensitive data in transit and at rest, reducing the risk of unauthorized access or data theft. • Input Validation and Sanitization: Prevents attacks like SQL injection or cross-site scripting by ensuring user inputs are properly handled. • Access Control and Role Management: Limits user permissions to only what's necessary for their role, minimizing the impact of insider threats or accidental misuse.
